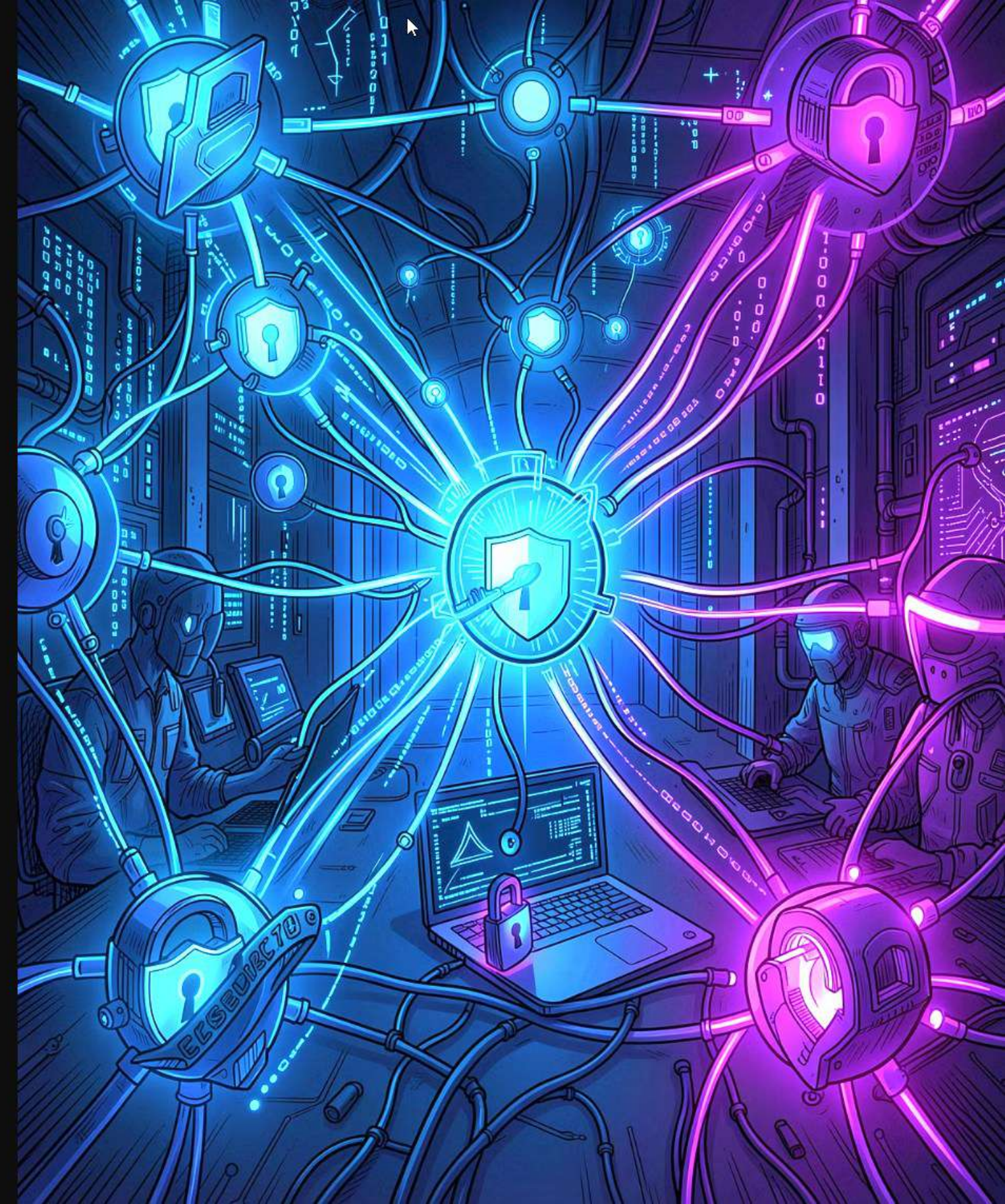


Analisi Null Session e ARP Poisoning

Studio delle vulnerabilità Null Session nei sistemi Windows e simulazione pratica di attacco ARP Poisoning tramite Ettercap in ambiente controllato.

SANTI LO FARO

21/05/2026



Obiettivi del Laboratorio

Due Minacce, Un Unico Obiettivo

Null Session

Analisi della vulnerabilità nei sistemi Windows legacy e tecniche di mitigazione.

ARP Poisoning

Simulazione pratica di attacco Man-in-the-Middle con Ettercap e Wireshark su Kali Linux.

Tutte le attività sono state eseguite esclusivamente in ambiente controllato e a scopo didattico.

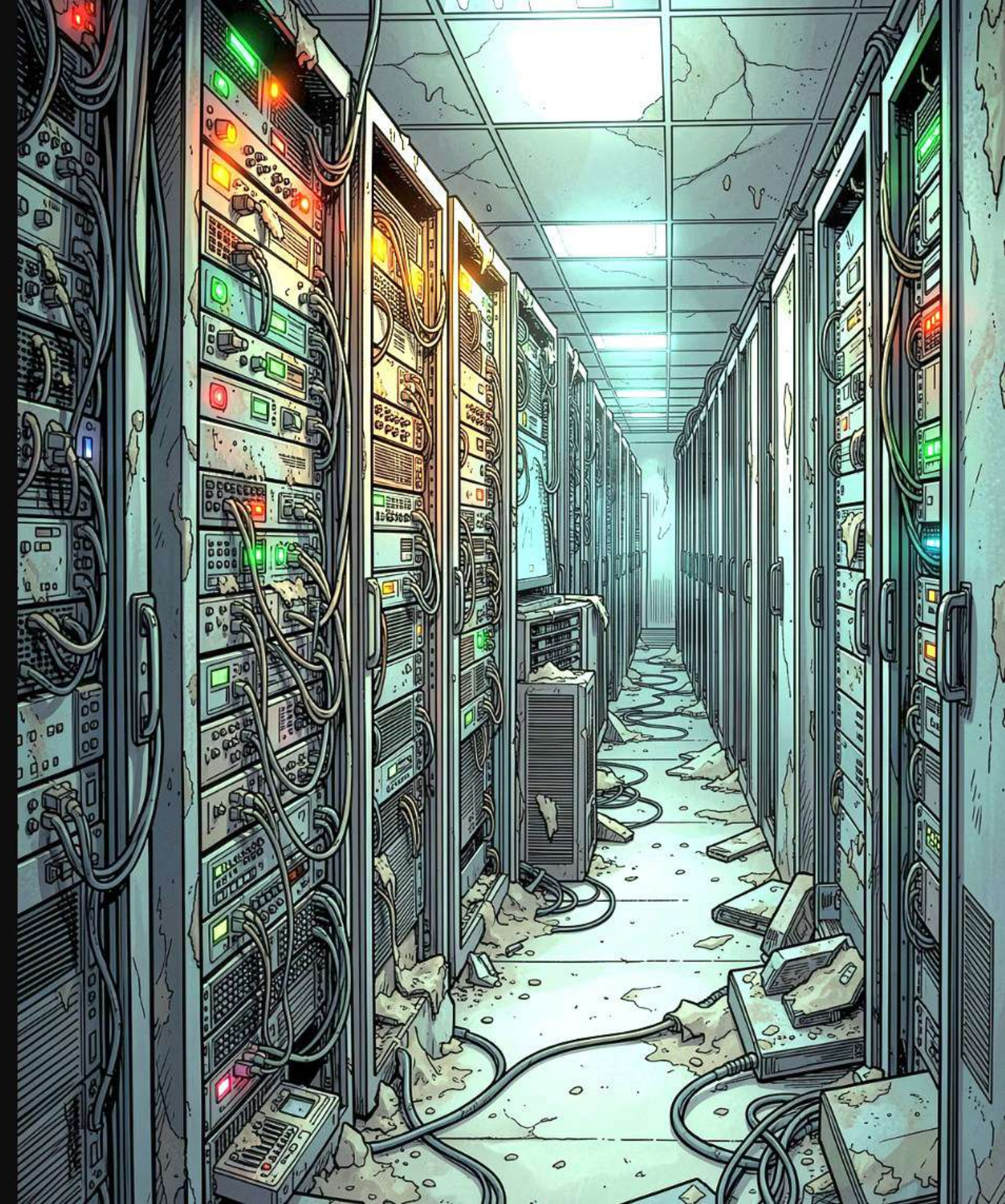
Vulnerabilità Null Session

La Null Session consente a un utente remoto di connettersi a un host Windows **senza credenziali**, sfruttando i servizi SMB e NetBIOS. L'attaccante può enumerare utenti, condivisioni di rete e configurazioni di sistema.

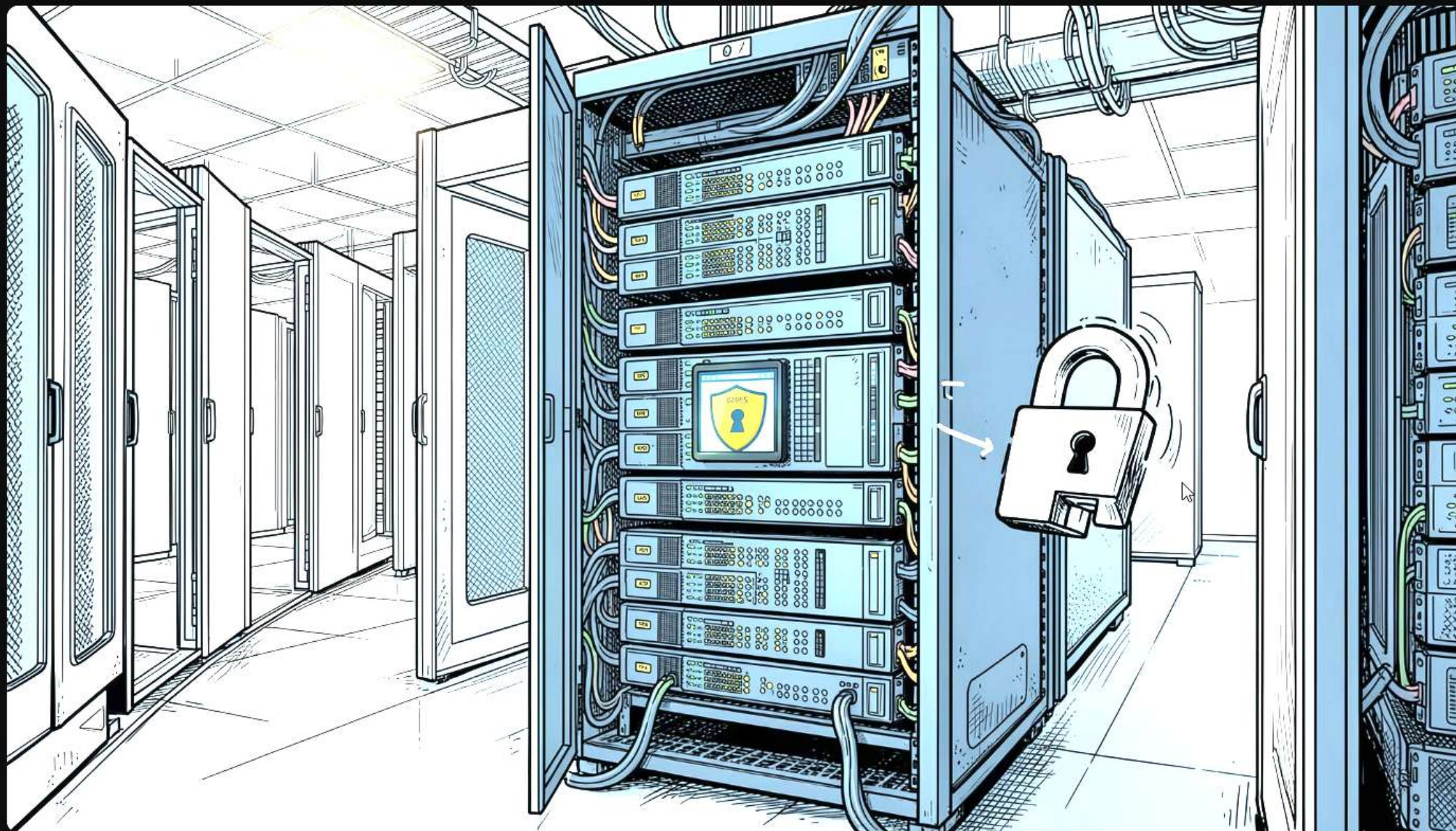
Windows NT / 2000

Windows XP

Server 2003

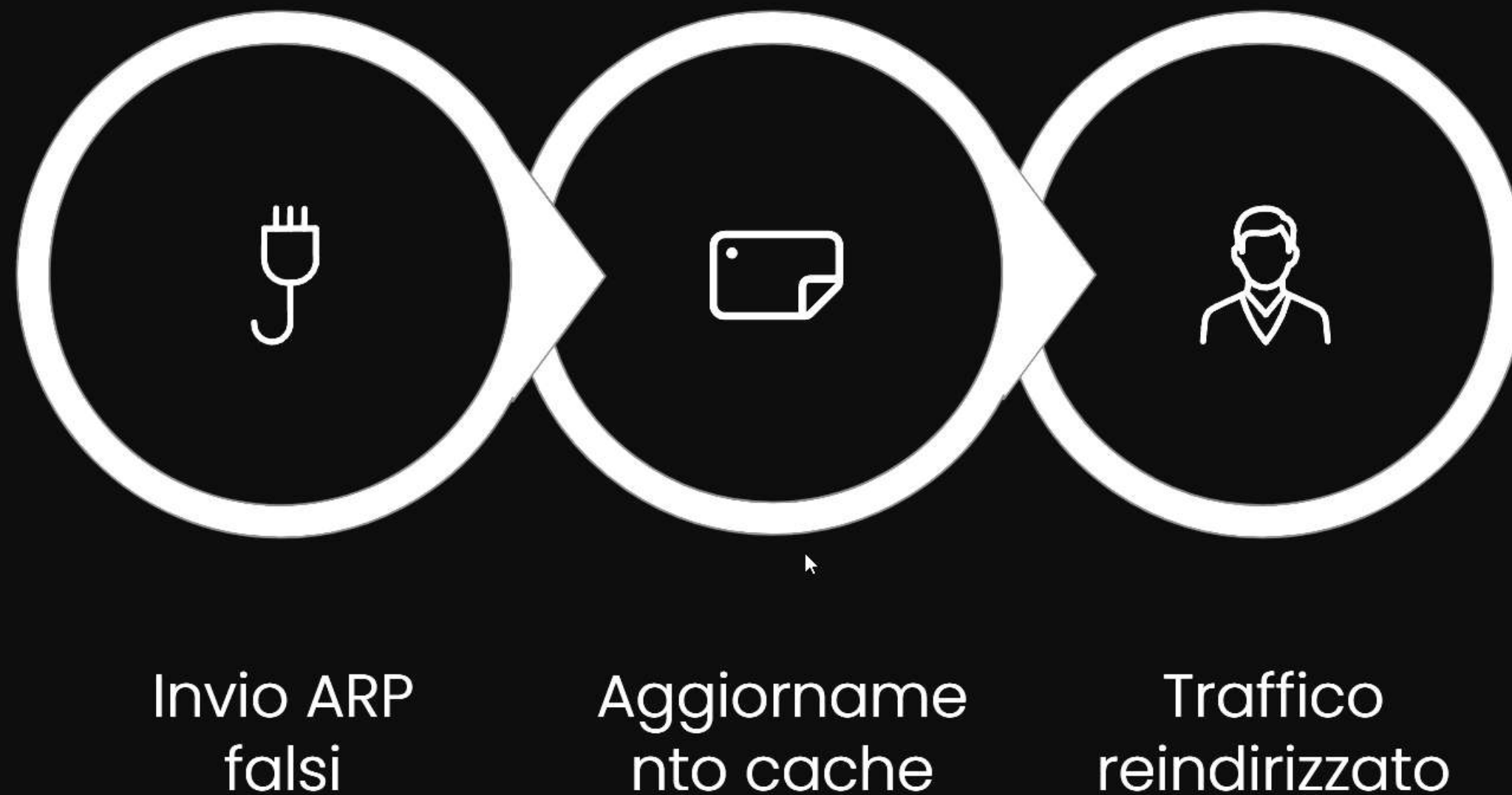


Mitigazione della Null Session



- **Disabilitare SMB/NetBIOS**
Riduce la superficie di attacco eliminando i servizi non necessari.
- **Firewall su TCP 139 / 445**
Blocca connessioni SMB da host non autorizzati.
- **Disattivare account Guest**
Impedisce accessi anonimi e attività di enumerazione.
- **Aggiornamenti OS**
Le patch Microsoft correggono vulnerabilità note con effort relativamente basso.

Come Funziona l'ARP Poisoning



Il protocollo ARP non prevede autenticazione: chiunque può inviare risposte false. L'attacco è possibile solo all'interno della stessa LAN.



Impatto dell'Attacco MITM



Intercettazione

Lettura di comunicazioni e credenziali non cifrate.



Manipolazione

Modifica dei pacchetti in transito tra vittima e gateway.



Furto credenziali

Username e password visibili in chiaro su traffico HTTP.

Mitigazione dell'ARP Poisoning



La cifratura è la difesa più efficace: anche se l'attaccante intercetta i pacchetti, **non può leggerne il contenuto**. La segmentazione con VLAN limita il raggio d'azione dell'attacco.

 Strumenti di monitoraggio: **Arpwatch**, **XArp**, **Snort** (IDS)

Simulazione Pratica con Ettercap

Ambiente di Test

Attaccante

Kali Linux + Ettercap

Gateway

192.168.1.1 → Target 1

Vittima

192.168.1.104 → Target 2

Procedura

01

Scan for Hosts sulla LAN

02

Selezione Target 1 e Target 2

03

Avvio ARP Poisoning via MITM

04

Verifica cache ARP vittima con `arp -a`

Analisi Traffico e Credenziali HTTP

Wireshark ha confermato il successo dell'attacco: visibili **reply ARP falsificati** e il MAC del gateway sostituito con quello di Kali Linux.

Collegandosi a **testphp.vulnweb.com** (HTTP non cifrato), Ettercap ha intercettato username e password in chiaro. Con HTTPS/TLS correttamente configurato, il contenuto sarebbe rimasto illeggibile.



Conclusioni

Sistemi Legacy

Configurazioni obsolete e protocolli non sicuri rappresentano un rischio reale nelle infrastrutture aziendali.

ARP è Insicuro

L'assenza di autenticazione nel protocollo ARP rende possibile il MITM su qualsiasi LAN non protetta.

Cifrare Sempre

HTTPS e TLS proteggono il contenuto anche quando il traffico viene intercettato.

- ✔ Il laboratorio ha dimostrato concretamente come vulnerabilità note possano essere sfruttate — e come le contromisure corrette le rendano inefficaci.